

RAPPORT D'AUDIT PRODUIT

Djola TikTak

Plateforme de Prise de Rendez-vous

Note globale : 62 / 100

Valeur marchande estimee : 15 000 000 - 25 000 000 FCFA

Aout 2025 | Audit confidentiel

TABLE DES MATIERES

1. Synthese executive	4
2. Audit fonctionnalite par fonctionnalite	4
2.1 Systeme d'authentification (8/10)	4
2.2 Systeme de reservation (8/10)	4
2.3 Dashboard de gestion (7/10)	5
2.5 Systeme de facturation (7/10)	5
2.5 Systeme de notifications (2/10)	5
2.6 Panneau d'administration (7/10)	5
Tableau recapitulatif des fonctionnalites	6
3. Architecture technique (13/20)	6
3.1 Stack technique	6
3.2 Base de donnees	6
3.3 Points techniques positifs	7
3.4 Problemes techniques	7
4. Securite (8/20)	7
4.1 Vulnerabilites critiques	7
4.2 Mesures en place	8
5. UX / Design (14/20)	8
5.1 Points forts	8
5.2 Points a ameliorer	8
6. Analyse des couts avant les premiers utilisateurs	8
6.1 Cout de developpement (investissement initial)	9
6.2 Cout mensuels d'infrastructure	9
6.3 Resume financier	9
7. Valeur marchande estimee	9

8. Propositions d'amelioration pour battre la concurrence	10
8.1 Corrections critiques (a faire immediatement)	10
8.2 Fonctionnalites pour battre la concurrence	10
8.3 Ameliorations techniques	11
9. Analyse concurrentielle	11
10. Conclusion et feuille de route	12

1. Synthese executive

Djola TikTok est une plateforme SaaS de prise de rendez-vous destinee aux professionnels africains (restaurants, coiffeurs, consultants, boutiques, agences, sante, formation). L'application est construite avec Next.js 16, React 19, TypeScript, Tailwind CSS 4, Supabase (PostgreSQL) et deployee sur Vercel. Elle offre un systeme de booking public, un dashboard de gestion complet, un systeme de facturation par plans avec paiements Chariow et Mobile Money (Orange Money, MTN MoMo), et un panneau d'administration.

L'audit revele un produit fonctionnel avec une architecture moderne et une couverture fonctionnelle etendue (19 pages, 22 routes API, 13 tables de donnees). Cependant, plusieurs fonctionnalites critiques sont incompletes : le systeme de notifications (rappels email, SMS, WhatsApp, vocaux) est entierement un stub, les cron jobs ne sont pas planifies, et des vulnerabilites de securite existent. Le score global attribue est de **62/100**, refletant un MVP solide mais necessitant des corrections importantes avant une mise en production a grande echelle. La valeur marchande estimee se situe entre 15 et 25 millions de FCFA.

62

NOTE GLOBALE SUR 100

Fonctionnalites	14 / 20	70%
Architecture technique	13 / 20	65%
Securite	8 / 20	40%
UX / Design	14 / 20	70%
Facturation	13 / 20	65%

2. Audit fonctionnalite par fonctionnalite

2.1 Systeme d'authentification (8/10)

Le systeme d'authentification repose sur Supabase Auth avec email et mot de passe. L'inscription collecte le nom d'entreprise, le telephone et l'email, puis cree un profil automatiquement via un trigger PostgreSQL. La verification email est implementee avec une page dediee et un bouton de renvoi. La connexion utilise les cookies SSR avec un middleware qui protege les routes du dashboard. Un mecanisme de timeout a 4 secondes prevent les erreurs 504 sur Vercel Edge. Un endpoint auto-confirm existe pour le developpement. Points forts : sessions securisees, middleware robuste, redirection automatique. Points faibles : pas d'authentification 2FA, pas de connexion OAuth (Google, Facebook), l'endpoint auto-confirm n'a aucune securite.

2.2 Systeme de reservation (8/10)

Le systeme de reservation est l'une des fonctionnalites les plus abouties. Il comprend un moteur de disponibilite qui genere des creneaux de 15 minutes en tenant compte des horaires hebdomadaires, des slots bloques et des rendez-vous existants. La prevention des chevauchements est double : contrainte GiST en base de donnees et verification application avant creation. Le flux public en 4 etapes (service, date, infos client, confirmation) est fluide et bien anime avec Framer Motion. La page publique par slug affiche une carte de visite professionnelle avec services, liens sociaux et modes de paiement. Points forts : engine de dispo solide, anti-double-booking, deduplication clients. Points faibles : pas de pagination sur les rendez-vous, pas de sync calendrier externe.

2.3 Dashboard de gestion (7/10)

Le dashboard offre une interface complete avec sidebar repliable sur desktop et navigation inferieure sur mobile. La page d'accueil affiche des statistiques (RDV du jour, de la semaine, nombre de clients et services) et les prochains rendez-vous. La gestion des services supporte le CRUD complet avec upload d'images et toggle actif/inactif. Les rendez-vous peuvent etre filters par statut (5 statuts) et mis a jour. La gestion des clients inclut la recherche et la deduplication par nom+telephone. Les disponibilites sont editees jour par jour avec des blocages de dates. Points forts : interface riche, animations fluides, mobile-first, plan gating integre. Points faibles : pas d'export de donnees, pas de vue calendrier, les stats sont basiques.

2.5 Systeme de facturation (7/10)

Le systeme de facturation comporte 3 plans (Starter 3 000 FCFA, Pro 10 000 FCFA, Business 25 000 FCFA/mois) avec facturation mensuelle ou annuelle (-17%). Deux providers de paiement sont integres : Chariow (paiement en ligne) et Mobile Money manuel (Orange Money, MTN MoMo). Les limites par plan sont stockees en base et verifiees coté serveur via un utilitaire plan-gate avec bypass admin. Le dashboard de facturation affiche les metres d'utilisation, l'historique des paiements et les alertes de consommation. Les webhooks Chariow gerent automatiquement l'activation et l'annulation des abonnements. Points forts : architecture billing solide, double methode de paiement, gating serveur. Points faibles : webhook Chariow sans verification de signature, pas de periode d'essai automatique apres inscription.

2.5 Systeme de notifications (2/10)

C'est le point le plus faible du produit. Les 4 providers de notification (Email, SMS, WhatsApp, Voix) sont des stubs qui ne font que logger dans la console. Le cron job de rappels cree des enregistrements en base mais n'appelle jamais le ReminderService. Aucun cron n'est configure dans vercel.json (tableau vide). L'integration ElevenLabs genere de l'audio mais sans mecanisme de livraison (pas de Twilio ou equivalent). En resume : la fonctionnalite de rappels est entierement simulee, zero notification reelle n'est envoyee aux clients ou aux professionnels.

2.6 Panneau d'administration (7/10)

Le panneau admin offre des metriques plateforme (profils, RDV, revenus, taux de croissance), la gestion des paiements manuels avec confirmation/rejet, et l'acces est restreint via la variable d'environnement ADMIN_EMAILS. L'interface est claire avec des cartes de statistiques et des

tableaux de donnees recentes. Le cron d'expiration des abonnements est implemente. Points faibles : pas de gestion des utilisateurs, pas de systeme de feedback, pas de logs d'activite admin.

Tableau recapitulatif des fonctionnalites

Fonctionnalite	Note /10	Statut
Authentification (login, register, forgot)	8	Operationnel
Reservation publique (4 etapes)	8	Operationnel
Dashboard gestion (services, RDV, clients)	7	Operationnel
Disponibilites et blocages	7	Operationnel
Profil public par slug	8	Operationnel
Facturation / Plans / Limites	7	Operationnel
Paiement Chariow	6	Partiel
Paiement Mobile Money	6	Partiel
Notifications / Rappels	2	Stub
Panneau administration	7	Operationnel
PWA installable	5	Operationnel
Theming (7 themes)	6	Operationnel
Gating par plan	8	Operationnel
Upload fichiers	6	Operationnel
Page de pricing	8	Operationnel

3. Architecture technique (13/20)

3.1 Stack technique

Le stack est moderne et bien choisi : Next.js 16 (App Router), React 19, TypeScript 5, Tailwind CSS 4, Supabase (PostgreSQL), Vercel pour le deploiement. Le package manager est Bun, les composants UI viennent de shadcn/ui (~45 composants), les animations de Framer Motion, les icones de Lucide React. L'architecture App Router permet les Server Components et le streaming. Le PWA est configure avec manifest et service worker.

3.2 Base de donnees

Supabase PostgreSQL avec 13 tables (7 core + 6 subscription). Les RLS (Row Level Security) sont activees sur toutes les tables. Les contraintes d'integrite incluent : contrainte GiST

anti-chevauchement, index uniques pour la deduplication clients, triggers de mise a jour automatique, 6 fonctions RPC (start_trial, activate_subscription, expire_subscriptions, get_usage_summary, consume_voice_credit, complete_voice_credit). Cependant, Prisma est configure pour SQLite en local mais n'est pas utilise en production, ce qui cree une incoherence.

3.3 Points techniques positifs

- Middleware avec timeout 4s pour eviter les 504 Vercel Edge
- Plan gating serveur avec fallback defaults si la DB n'est pas encore migree
- Bypass admin complet via ADMIN_EMAILS
- Service role client Supabase pour les endpoints non-authentifies (booking public)
- Validation Zod sur tous les inputs API
- Deduplication clients par nom + telephone
- Structure monorepo propre avec separation API/pages/components/lib

3.4 Problemes techniques

- Dependances inutilisees : next-auth, @mdxeditor/editor, react-markdown, recharts, @dnd-kit, @tanstack/react-query, @tanstack/react-table, zustand, pg, next-intl
- Prisma configure pour SQLite mais jamais utilise en production
- Pas de rate limiting sur aucun endpoint
- Pas de pagination sur les listes API
- Bulk update des disponibilites non-atomique (delete + insert sans transaction)
- Cron jobs definis mais jamais planifies dans vercel.json

4. Securite (8/20)

La securite est le domaine le plus critique a corriger. Bien que des mesures solides existent (RLS, auth checks, plan gating, Zod validation), plusieurs vulnerabilites graves ont ete identifiees qui doivent etre corrigees avant tout lancement public.

4.1 Vulnerabilites critiques

- 1. Endpoint auto-confirm sans authentication (CRITIQUE) :** L'endpoint /api/auth/auto-confirm permet a quiconque de confirmer l'email de n'importe quel utilisateur en passant simplement une adresse email. Aucune verification d'identite n'est effectuee. Cela signifie qu'un attaquant peut creer un compte avec n'importe quel email, puis le confirmer sans acceder a la boite mail.
- 2. Webhook Chariow sans verification de signature (CRITIQUE) :** La fonction verifyWebhook() retourne toujours true. Un attaquant peut simuler des webhooks Chariow pour activer des abonnements gratuitement. Cela compromet tout le systeme de facturation.
- 3. Pas de rate limiting (HAUT) :** Les endpoints de booking public, d'inscription et de connexion sont vulnerables aux attaques par force brute et aux abus. Un bot peut creer des

milliers de rendez-vous ou de comptes.

4.2 Mesures en place

- RLS activees sur toutes les 13 tables avec politiques granulaires
- Verification authentication sur chaque endpoint protege
- Verification d'appartenance (ownership check) sur toutes les operations CRUD
- Validation Zod des inputs sur tous les endpoints
- Cron endpoints proteges par CRON_SECRET header
- Upload de fichiers : whitelist de buckets, limite 5MB, types autorises

5. UX / Design (14/20)

L'interface utilisateur est bien construite avec une approche mobile-first. Le design systeme utilise shadcn/ui (composants Radix) avec une palette emerald/green coherente. Les animations Framer Motion apportent du dynamisme (transitions de pages, indicateurs de sidebar, etats de chargement). La sidebar desktop est repliable, la navigation mobile est en barre inferieure fixe. Sept themes sont disponibles (default, dark, emerald, ocean, sunset, rose, midnight) avec des variables CSS completes. Le mode sombre est supporte via next-themes. Tous les textes sont en francais (locale fr_CM) avec formatage des dates et de la monnaie (FCFA) adaptes au marche africain.

5.1 Points forts

- Mobile-first avec bottom nav et responsive breakpoints
- Animations fluides (page transitions, form animations, loading states)
- 7 themes avec variables CSS completes et dark mode
- Skeletons de chargement sur toutes les pages
- Toasts Sonner pour les feedbacks utilisateur
- Banniere d'abonnement expire dans le dashboard

5.2 Points a ameliorer

- Pas de vue calendrier (seulement liste de RDV)
- Pas d'export de donnees (CSV, PDF)
- Liens CGU et politique de confidentialite non fonctionnels
- Pas de systeme d'onboarding guide pour les nouveaux utilisateurs
- Image next/image non utilisee partout (service images en raw img)

6. Analyse des couts avant les premiers utilisateurs

Voici l'analyse detaillee de tous les couts engages avant d'acquérir le premier utilisateur payant, en tenant compte des couts de developpement, d'infrastructure et operationnels.

6.1 Couts de developpement (investissement initial)

Poste	Cout estime (FCFA)	Duree
Developpement frontend (19 pages)	4 000 000 - 6 000 000	4-6 semaines
Developpement backend (22 API routes)	3 000 000 - 5 000 000	3-5 semaines
Systeme de facturation (Chariow + Mobile Money)	500 000 - 2 500 000	2-3 semaines
UX/UI Design + Themes	800 000 - 1 500 000	1-2 semaines
Tests et correction de bugs	500 000 - 1 000 000	1 semaine
TOTAL DEVELOPPEMENT	9 800 000 - 16 000 000	11-17 semaines

6.2 Couts mensuels d'infrastructure

Service	Forfait	Cout mensuel (FCFA)	Cout annuel (FCFA)
Vercel (Hobby)	Gratuit (puis Pro \$20/mois)	0 - 12 000	0 - 144 000
Supabase (Free)	500 MB DB, 50K MAU	0	0
Supabase (Pro)	8 GB DB, 100K MAU	25 000 (\$25)	300 000
Domaine (.cm)	Nom de domaine	2 500	30 000
Chariow	Commission sur transactions	Variable	Variable
ElevenLabs (voix)	Pay-per-use	Variable	Variable

6.3 Resume financier

Cout total avant le premier utilisateur payant : 9,8 a 16 millions FCFA (investissement initial de developpement). Les couts mensuels operationnels sont de **0 a 37 500 FCFA/mois** (en restant sur les forfaits gratuits) ou **25 000 a 37 500 FCFA/mois** avec Supabase Pro. Avec 10 abonnements Pro a 10 000 FCFA/mois, le revenu mensuel serait de 100 000 FCFA, couvrant largement les couts operationnels. Le seuil de rentabilite est atteint avec environ 3-4 abonnements Pro ou 2 abonnements Business par mois.

7. Valeur marchande estimee

L'estimation de la valeur marchande se base sur plusieurs methodes : le cout de reproduction (combien couterait de recreeer l'application), la valeur des actifs techniques (code, architecture, composants reutilisables), et le potentiel de revenus sur le marche cible (professionnels africains francophones).

Critere	Estimation (FCFA)	Justification
Cout de reproduction	10 000 000 - 16 000 000	Based on 11-17 semaines de dev senior
Valeur du code source	8 000 000 - 12 000 000	19 pages, 22 API, 13 tables, billing complet
Valeur du design systeme	1 000 000 - 2 000 000	7 themes, 45+ composants, mobile-first
Potentiel de marche (3 ans)	5 000 000 - 15 000 000	Marche africain en croissance
Fourchette basse	15 000 000	Scenario pessimiste
Fourchette haute	25 000 000	Scenario optimiste avec traction

8. Propositions d'amelioration pour battre la concurrence

8.1 Corrections critiques (a faire immediatement)

Priorite 1 - Securiser l'endpoint auto-confirm : Ajouter une verification que seul un utilisateur authentifie avec le role admin peut appeler cet endpoint, ou mieux, le supprimer et utiliser l'API Admin de Supabase avec le service role key de maniere securisee. Cette vulnerabilite permet a quiconque de creer des comptes verifies.

Priorite 2 - Implementer la verification de signature webhook Chariow : Utiliser le secret CHARIOW_WEBHOOK_SECRET pour verifier le HMAC-SHA256 de chaque webhook entrant. Sans cela, le systeme de facturation entier peut etre contourné.

Priorite 3 - Ajouter le rate limiting : Implementer un rate limiter sur les endpoints publics (booking, register, login) avec une librairie comme upstash/ratelimit ou un middleware Vercel. Limiter a 10 requetes/minute pour les endpoints sensibles.

8.2 Fonctionnalites pour battre la concurrence

1. Notifications reelles (impact maximum) : Integrer Brevo (ex-Sendinblue) pour les emails, Twilio ou Africa's Talking pour les SMS et la voix. C'est la fonctionnalite la plus attendue par les utilisateurs et celle qui differencie le plus. Les concurrents comme Calendly et Doodle ont des rappels fonctionnels. L'absence de rappels reels est un bloqueur d'adoption majeur. Cout estime : 500 000 - 1 000 000 FCFA.

2. Synchronisation calendrier (Google Calendar, Outlook) : Permettre aux professionnels de synchroniser leurs rendez-vous avec leur calendrier principal. C'est une fonctionnalite attendue par tous les professionnels qui utilisent deja un calendrier. Utiliser l'API Google Calendar et l'API Microsoft Graph. Les concurrents comme Calendly et Square Appointments offrent cette fonctionnalite.

3. Application mobile native : Le PWA est un bon debut, mais une application mobile native (React Native ou Flutter) avec notifications push natives et raccourcis serait un avantage competitif majeur sur le marche africain ou les utilisateurs sont majoritairement sur mobile.

Les notifications push natives sont plus fiables que les notifications web push.

4. Systeme d'avis et recommandations : Permettre aux clients de laisser des avis apres un rendez-vous. Afficher une note moyenne sur la page publique du professionnel. Cela cree de la confiance et ameliore le SEO. Aucun concurrent local ne le fait.

5. Gestion d'equipe multi-professionnel : La limite max_employees existe mais la fonctionnalite n'est pas implementee. Permettre a un profil Pro (3 professionnels) ou Business (10 professionnels) d'ajouter des collaborateurs avec leur propre calendrier. C'est essentiel pour les salons, les cliniques et les restaurants.

6. Analytics avances et rapports : Ajouter des graphiques de tendances (RDV par semaine, mois, revenus), des taux de completion, de no-show, et des rapports exportables. Utiliser Recharts (deja en dependances). Cela justifie le plan Business.

7. Modeles de rendez-vous recurrents : Permettre aux clients de reserver le meme creneau chaque semaine ou chaque mois (ex : cours de sport le mardi a 18h). C'est une fonctionnalite tres demandee pour les cours, les seances de suivi et les rendez-vous medicaux reguliers.

8.3 Ameliorations techniques

- Supprimer les 10+ dependances inutilisees (next-auth, recharts, zustand, etc.) pour reduire la taille du bundle
- Corriger l'incoherence Prisma (SQLite en local, Supabase en prod) - choisir un seul ORM
- Ajouter la pagination sur toutes les listes API (RDV, clients, services)
- Rendre la mise a jour des disponibilites atomique avec une transaction PostgreSQL
- Configurer les cron jobs dans vercel.json pour les rappels et l'expiration
- Ajouter l'internationalisation (next-intl est deja en dependances) pour cibler l'Afrique de l'Ouest et l'Afrique de l'Est
- Implementer les pages CGU et politique de confidentialite (liens actuellement casses)
- Ajouter OAuth (Google, Facebook) pour simplifier l'inscription

9. Analyse concurrentielle

Critere	Djola TikTok	Calendly	Doodle	Square Appointments
Prix local (FCFA)	3 000 - 25 000	Gratuit / \$16	Gratuit / \$7	\$15 - \$27
Mobile Money	Oui (OM, MTN)	Non	Non	Non
Rappels IA vocaux	En dev (stub)	Non	Non	Non
Multi-langue	Francais uniquement	Multi	Multi	Multi
PWA	Oui	Non	Non	Non
Page publique	Oui (slug)	Oui	Oui	Oui
Equipe multi-pro	En dev	Oui (Team)	Non	Oui
Calendrier sync	Non	Oui	Oui	Oui

Paielement local	Oui (Chariow)	Stripe/PayPal	Stripe/PayPal	Stripe
Avantage cle	Mobile Money + IA	Maturite	Simplicite	Ecosysteme

Le principal avantage competitif de Djola TikTok est l'integration du Mobile Money (Orange Money et MTN MoMo), qui est le mode de paiement dominant en Afrique francophone. Calendly, Doodle et Square ne supportent pas ces methodes de paiement, ce qui cree une barriere a l'entree pour les professionnels africains. Le second avantage est la promesse de rappels vocaux IA (via ElevenLabs), unique sur ce marche. Pour battre la concurrence, Djola TikTok doit : (1) rendre les notifications operationnelles, (2) ajouter la synchronisation calendrier, (3) developper l'application mobile native, et (4) exploiter son avantage Mobile Money comme argument marketing principal.

10. Conclusion et feuille de route

Djola TikTok est un MVP fonctionnel avec une base technique solide et un positionnement strategique fort sur le marche africain grace au Mobile Money. Cependant, pour atteindre la maturite produit necessaire a une adoption a grande echelle, 3 actions sont indispensables : (1) corriger les 3 vulnerabilites de securite critiques, (2) deployer un vrai systeme de notifications, et (3) ajouter la synchronisation calendrier. Avec ces corrections, le produit pourrait atteindre une note de 80/100 et etre pret pour une commercialisation agressive.

Phase	Action	Delai	Impact
Phase 1 (Urgent)	Corriger les 3 vuln. securite	1 semaine	Critique
Phase 1	Deployer rappels email (Brevo)	1 semaine	Eleve
Phase 2	Rate limiting + pagination API	1 semaine	Moyen
Phase 2	Sync Google Calendar	2 semaines	Eleve
Phase 3	Notifications SMS + WhatsApp	2 semaines	Eleve
Phase 3	App mobile native (React Native)	6-8 semaines	Tres eleve
Phase 4	Systeme d'avis clients	1 semaine	Moyen
Phase 4	Analytics avances + exports	2 semaines	Moyen